

PLAN DE PREVENCIÓN Y SEGURIDAD BASADO EN NIST

1. OBJETIVO DEL PLAN

El presente plan de prevención tiene como objetivo establecer medidas de seguridad orientadas a:

- prevenir incidentes de seguridad,
- reducir la superficie de ataque,
- proteger activos críticos,
- minimizar vulnerabilidades,
- y mejorar la capacidad de detección y respuesta ante amenazas.

El plan se basa en recomendaciones y buenas prácticas inspiradas en:

- NIST Cybersecurity Framework (CSF),
- y NIST SP 800-61.

2. ALCANCE

El plan aplica sobre la infraestructura utilizada durante el proyecto:

- Debian Linux,
- Apache2,
- MariaDB,
- WordPress,
- SSH,
- servicios de red,
- archivos críticos,
- y usuarios con acceso administrativo.

3. IDENTIFICACIÓN DE ACTIVOS CRÍTICOS

Activos principales

Activo	Criticidad
Servidor Debian	Alta
Apache2	Alta
MariaDB	Alta
WordPress	Alta
SSH	Alta
wp-config.php	Crítica
Credenciales	Crítica
Configuración Apache	Alta

4. PRINCIPALES RIESGOS IDENTIFICADOS

Riesgos detectados

Riesgo	Impacto
Acceso remoto inseguro SSH	Alto
Contraseñas débiles	Alto
FTP inseguro	Alto
XMLRPC habilitado	Medio-Alto
Enumeración Apache	Medio
Servicios innecesarios	Medio
Exposición de credenciales	Alto

5. MEDIDAS PREVENTIVAS IMPLEMENTADAS

5.1 Hardening SSH

Medidas:

- deshabilitación login root,
- eliminación autenticación por contraseña,
- recomendación uso claves SSH.

Configuración:

```
PermitRootLogin no  
PasswordAuthentication no
```

5.2 Protección de credenciales

Medidas:

- sustitución de contraseñas débiles,
- protección de archivos críticos,
- permisos restrictivos.

Configuración aplicada:

```
chmod 600 /var/www/html/wp-config.php
```

5.3 Reducción de superficie de ataque

Servicios deshabilitados:

- FTP (vsftpd)
- Avahi

- CUPS
- Exim4

Objetivo:

- reducir puertos expuestos,
- minimizar servicios vulnerables,
- disminuir posibilidades de explotación.

5.4 Protección WordPress

Medidas:

- deshabilitación XMLRPC,
- protección archivos sensibles,
- reducción componentes expuestos.

Resultado:

- mitigación de fuerza bruta,
- mitigación pingbacks,
- reducción automatización ataques.

5.5 Hardening Apache

Medida implementada:

Options -Indexes +FollowSymLinks

Objetivo:

- evitar enumeración directorios,
- ocultar estructura interna,
- reducir exposición información.

6. CONTROLES PREVENTIVOS RECOMENDADOS

6.1 Firewall

Implementar:

- UFW,
- iptables,
- o firewall perimetral.

Objetivo:

- limitar puertos,
- restringir accesos,
- controlar tráfico.

6.2 Monitorización continua

Recomendaciones:

- revisión logs,
- alertas automáticas,
- detección actividad sospechosa.

Herramientas recomendadas:

- Wazuh
- Fail2Ban
- OSSEC
- SIEM

6.3 Gestión de vulnerabilidades

Medidas:

- escaneos periódicos,
- revisión configuraciones,
- validación servicios.

Herramientas:

- Nmap
- Nessus
- OpenVAS
- Lynis

6.4 Gestión de actualizaciones

Objetivo:

- reducir vulnerabilidades conocidas.

Recomendaciones:

- actualizar Debian,
- actualizar Apache,
- actualizar WordPress,
- actualizar plugins y paquetes.

6.5 Backups periódicos

Elementos críticos:

- WordPress,
- MariaDB,
- configuraciones,
- scripts,

- evidencias.

Objetivo:

- recuperación rápida,
- continuidad operativa.

7. PLAN DE RESPUESTA PREVENTIVA

Modelo basado en NIST

Fases:

1. Preparación
2. Identificación
3. Contención
4. Erradicación
5. Recuperación
6. Lecciones aprendidas

8. VALIDACIONES DE SEGURIDAD

Verificaciones periódicas

Revisiones:

- puertos abiertos,
- servicios activos,
- permisos archivos,
- validación SSH,
- XMLRPC,
- persistencia mitigaciones.

Objetivo:

- detectar cambios inseguros,

- validar hardening,
- mantener postura seguridad.

9. MEJORA CONTINUA

Recomendaciones

- auditorías periódicas,
- revisión políticas,
- formación seguridad,
- monitorización continua,
- actualización procedimientos.

Objetivo:

- adaptación nuevas amenazas,
- mantenimiento controles,
- mejora continua seguridad.

10. CONCLUSIÓN

La implementación del presente plan de prevención permitió establecer un conjunto de controles y medidas orientadas a reducir riesgos y mejorar la seguridad del entorno Debian WordPress analizado.

Las medidas aplicadas permitieron:

- reducir la superficie de ataque,
- proteger servicios críticos,
- fortalecer accesos remotos,
- y mejorar la postura general de seguridad del sistema.

El plan se encuentra alineado con recomendaciones y buenas prácticas basadas en NIST, especialmente en:

- prevención,
- hardening,
- gestión de riesgos,

- y respuesta ante incidentes.